

Engage-Agent: A 2-Layer MITRE Engage-driven LLM Agent in a Honeynet

一、研究動機

Q1：為什麼選擇 Honeynet 而不是 Honeypot？

因為現代企業攻擊通常不是停留在單一主機，而是會包含憑證濫用、權限提升、橫向移動與 AD 滲透等多階段行為。Honeypot 雖然可以收集單機互動資料，但很難支援跨主機攻擊路徑；Honeynet 則能提供多台主機、帳號、服務與網路關係，比較適合觀察攻擊者在企業環境中的完整行為。

Q2：你觀察到現有研究最大的缺陷是什麼？

最大的缺陷是「互動能力」和「環境真實性」通常是分開的。Adaptive honeypot 有動態互動能力，但多半是 single-host、reply-level；honeynet 有多主機真實環境，但多半偏靜態或被動觀察。也就是說，現有研究缺少一個能在真實多主機環境中，根據攻擊者行為動態調整環境的統一架構。

Q3：為什麼認為 MITRE Engage 比 ATT&CK 更適合本研究？

ATT&CK 主要描述攻擊者的 tactics、techniques 和 procedures，適合用來分析攻擊行為；但本研究的重點是 defender 要如何主動欺敵、引導攻擊者。MITRE Engage 本來就是針對 deception、active defense 和 adversary engagement 設計，能提供 defender-side 的活動分類，所以更適合作為本系統設計 engagement strategy 和 MCP tools 的依據。

Q4：你最想解決的核心問題是什麼？

核心問題是：如何在一個持久化的多主機蜜網中，根據攻擊者近期行為動態修改環境，引導攻擊者往更深層的多階段攻擊路徑前進，同時保持主機、帳號、憑證、服務和 artifact 的一致性。

二、研究方法

Q5：為什麼採用雙層 LLM 而不是單層？

因為這個任務同時包含兩種不同能力：第一是理解攻擊者意圖並決定欺敵策略，第二是把策略轉換成可執行的工具參數。單層 LLM 要同時做 intent reasoning、tool selection 和 argument generation，容易產生不穩定或重複的工具使用。雙層架構把高階語意判斷和低階部署規劃拆開，可以讓每一層任務更清楚，也更容易控制輸出品質。

Q6：Strategist 與 Planner 如何分工？

Strategist 負責看近期 command context，推論攻擊者目前目標，決定 engagement strategy，並選出適合的 MCP tools。Planner 不再重新判斷攻擊意圖，而是根據 Strategist 給的策略、選定工具和 tool specification，產生具體的工具參數。簡單說，Strategist 決定「要做什麼」，Planner 決定「怎麼部署」。

Q7：MCP 在系統中的角色是什麼？

MCP 是 LLM 和真實環境修改工具之間的結構化介面。它把可用的環境修改能力包成有 schema、有參數限制、有模板的工具，讓 LLM 不需要直接生成 Ansible script，而是只需要產生工具名稱和參數。這樣可以降低自由生成腳本造成的語法錯誤與執行失敗，也讓系統的 action space 更可控。

Q8：為什麼選擇 AD Domain 作為實驗環境？

因為 AD 是企業環境中非常核心的身份與權限管理基礎，很多真實攻擊都會圍繞帳號、權限、群組、憑證與橫向移動展開。若要評估多階段企業攻擊，AD domain 能提供比較真實的身份關係、權限依賴和跨主機攻擊路徑，所以比一般單機或簡單 lab 更適合作為 honeynet substrate。

Q9：為什麼採用環境修改而非回覆生成？

回覆生成雖然可以快速產生看起來合理的 output，但攻擊者後續可能會用其他指令驗證檔案、帳號、服務或主機關係是否真的存在。如果只是生成文字，很容易在長程互動中破功。環境修改則是直接改變真實蜜網狀態，讓攻擊者看到的結果來自實際系統行為，因此比較能維持跨步驟、跨主機的一致性。

三、創新性

Q10：與 HoneyGPT 最大差異是什麼？

HoneyGPT 的核心是利用 LLM 直接產生 terminal honeypot 的回覆，重點在 reply generation。本研究的核心不是產生回覆，而是修改真實多主機 AD honeynet，讓回覆自然來自真實系統狀態。因此差異在於：HoneyGPT 是 response-level deception，而 Engage-Agent 是 environment-level deception。

Q11：與 QRASSH 最大差異是什麼？

QRASSH 是 single-host SSH honeypot，使用 Q-learning 選擇 allow、block、substitute、insult 等回覆操作，主要是在單一 SSH session 中延長互動。本研究則是 multi-host honeynet，透過 LLM 理解攻擊意圖並用 MCP tools 修改真實 AD 環境，目標是支援橫向移動和多階段攻擊，而不只是單機互動。

Q12：你的研究最有價值的創新點是什麼？

我認為最有價值的是把 LLM-based adaptive deception 從單機回覆層級推進到真實多主機環境層級。系統不是單純讓 LLM 假裝 shell，而是讓 LLM 透過 bounded MCP tools 修改真實 AD honeynet，並用雙層架構把攻擊意圖理解和工具參數規劃分開。這讓欺敵行為更可驗證、更一致，也更適合企業級攻擊場景。

Q13：如果沒有雙層架構，效果會差多少？

在 end-to-end attack depth 上，差距不是最大，因為三個 Engage-Agent variants 都共享同一個 AD-domain honeynet，所以主要提升來自多主機環境本身。不過在 Planner benchmark 中，雙層加 fine-tuning 的 composite score 相比 one-layer 提高約 67%，表示雙層架構對工具選擇、參數品質、一致性和避免重複工具使用有明顯幫助。

四、成果評估

Q14：為什麼使用 Attack Depth 作為指標？

因為本研究的目標不是只延長 session，也不是只讓攻擊者多打指令，而是引導攻擊者往更深層的多階段攻擊行為前進。Attack Depth 可以衡量攻擊者是否從 discovery 進展到 credential access、privilege escalation、lateral movement 甚至更後面的階段，所以比單純互動時間更能反映 engagement 效果。

Q15：Perceived Real-System Rate 如何衡量？

每個 command response 會根據 command、stdout、stderr 和 exit code 被判斷為 realistic、synthetic 或 inconclusive，並依照 evidence strength 轉成 soft realism score。最後對所有 response 的分數取平均，得到 Perceived Real-System Rate。所以它不是單純二分法的真或假，而是衡量整體互動看起來像真實系統的程度。

Q16：哪個實驗結果最符合你的預期？

最符合預期的是 Engage-Agent 在 attack depth 和 perceived realism 上明顯優於 single-host baselines。這符合我的核心假設：如果攻擊者需要多階段與跨主機行為，真實 AD-domain honeynet 加上環境修改會比單機 honeypot 或 reply generation 更能支撐深入攻擊路徑。

Q17：哪個結果最讓你意外？

比較意外的是三個 Engage-Agent variants 在 end-to-end depth 和 diversity 上差距沒有想像中大。這表示多主機 AD 環境本身對攻擊深度和行為多樣性的影響非常大，而雙層架構的優勢比較明顯反映在 Planner plan quality 和 lateral movement support 上，不一定會在每個 end-to-end 指標都放大成巨大差距。

五、未來研究

Q18：如果繼續攻讀博士，你會如何延伸這項研究？

我會從三個方向延伸。第一是加入 human red-team evaluation，確認系統對真實攻擊者是否有效。第二是加入 feedback-aware adaptation，讓系統不只部署 deception artifact，還能判斷攻擊者是否真的看到、使用或忽略它，再決定下一步。第三是把環境從單一 AD-domain 擴展到 cloud、container、更多企業服務與更大規模網路。

Q19：是否能結合強化學習取代部分 LLM 決策？

可以，但我認為比較適合取代或輔助部分決策，而不是完全取代 LLM。LLM 適合處理開放式 command context 和語意推論；RL 比較適合在 action space 清楚、reward 可定義、可大量模擬的情況下學習策略。未來可以用 RL 來學習何時介入、選擇哪類 Engage activity，或根據攻擊深度與工具成功率調整策略；但具體參數生成仍然可以保留給 Planner LLM。

Q20：是否能應用到真實企業 SOC 或智慧防禦系統？

有機會，但需要先解決安全邊界、部署成本和誤操作風險。比較實際的做法不是直接修改 production system，而是在企業內部部署隔離的 deception environment，或把它接到 SOC 流程中，作為高互動誘捕與威脅情資收集系統。當偵測到可疑行為時，系統可以把攻擊者導向受控的 AD honeynet，動態建立 decoy credentials、fake accounts、breadcrumbs 和 service artifacts，協助 SOC 收集更完整的攻擊行為。